

CO5 – AT1 Industry Problem Task

ITA1407 - ETHICAL HACKING

Name: Pranov Raaj G

Reg No: 192372355

Question 1 – Windows Domain Attack Analysis

Brief Explanation

The organization has 150 Windows domain systems. The task is to determine how many systems are compromised in the initial attack, estimate the second-stage spread through SMB lateral movement, compare the result with the 70% compromise threshold, and identify the most critical vulnerability for immediate mitigation.

Key Calculations

- Anonymous enumeration systems = $150 \times 45\% = 67.5 \approx 68$ systems
- Initially compromised systems = $68 \times 60\% = 40.8 \approx 41$ systems
- Second-stage spread = $41 \times 3 \times 0.3 = 36.9 \approx 37$ systems
- Total compromised systems = $41 + 37 = 78$ systems
- Compromise percentage = $(78 \div 150) \times 100 = 52\%$

Run Comment (Expected Result)

The expected compromise is **78 systems (52%)**, which is below the 70% threshold. However, the attack still represents a serious security incident because lateral movement can continue if no action is taken.

Verification Note

Recalculated independently: $150 \times 0.45 = 67.5 \rightarrow 68$; $68 \times 0.60 = 40.8 \rightarrow 41$; second-stage spread $41 \times 3 \times 0.3 = 36.9 \rightarrow 37$; total = $41 + 37 = 78$, i.e. $78/150 = 52\%$. All figures in the submission are arithmetically correct and consistent.

Evaluation / Comment

NULL sessions should be disabled first because they allow anonymous reconnaissance. After that, RPC exposure and weak shared folders should be secured to prevent further lateral movement.

Additional Insight

Although 52% falls under the 70% large-scale-compromise threshold, this is a single-round estimate. If the same 0.3 success probability and 3-attempt spread pattern is allowed to repeat across further rounds (i.e. the attacker keeps pivoting from newly compromised hosts), the infection could realistically exceed 70% within two to three additional rounds, so "below threshold" should not be read as "safe" — it only reflects the state after one lateral-movement cycle. Recommended controls: disable NULL/anonymous SMB sessions via registry (RestrictAnonymous), restrict RPC endpoint mapper exposure with firewall rules, enforce SMB signing, and segment the domain with tiered administration to cap lateral movement blast radius.

Question 2 – RPC Exploitation

Brief Explanation

Out of 120 systems, only those exposing RPC services are considered. The question requires calculating the expected successful compromises, estimating IDS detection alerts, and evaluating whether a stealth-focused attacker would continue exploiting the systems.

Key Calculations

- RPC-enabled systems = 70
- Vulnerable systems = $70 \times 40\% = 28$ systems
- Expected successful compromises = $28 \times 0.5 = 14$ systems
- Expected IDS alerts = $28 \times 0.25 = 7$ alerts

Run Comment (Expected Result)

The attacker is expected to compromise **14 systems**, but approximately **7 detection alerts** are likely to be generated during exploitation.

Verification Note

Recalculated independently: vulnerable systems = $70 \times 0.40 = 28$; expected compromises = $28 \times 0.5 = 14$; expected alerts = $28 \times 0.25 = 7$. Figures confirmed correct.

Evaluation / Comment

A stealth-oriented attacker would probably avoid repeated exploitation because multiple IDS alerts increase the chance of detection. Alternative methods such as phishing or credential theft may be preferred.

Additional Insight

A detection-to-compromise ratio of 7 alerts for 14 successful compromises (0.5 alerts per successful host) is high enough that a well-tuned SOC should catch the campaign mid-attack, so from the attacker's perspective the expected value of continuing may still be positive only if the target's alerts are not actively triaged. This highlights that expected-

value calculations for the attacker must be paired with the defender's mean-time-to-detect and mean-time-to-respond; if MTTD is short relative to the exploitation window, the effective detection probability per attempt should be treated as a lower bound, not the actual risk. Recommended mitigation: patch the 28 vulnerable RPC endpoints, restrict RPC/DCOM exposure to only required hosts, and tune IDS alert thresholds so that 7 alerts trigger an automated response rather than manual review.

Question 3 – Linux Server Risk

Brief Explanation

The Linux server exposes four internet-facing services. The objective is to calculate the probability that at least one service is vulnerable, determine the overall probability of complete system compromise after privilege escalation, and assess whether improving file permissions alone reduces risk.

Key Calculations

- $P(\text{at least one vulnerable service}) = 1 - (0.7 \times 0.8 \times 0.75 \times 0.85)$
- $= 1 - 0.357 = 0.643$
- $= 64.3\%$
- $\text{Overall compromise} = 64.3\% \times 0.5 = 32.15\%$

Run Comment (Expected Result)

There is a **64.3%** chance that at least one service is exploitable and a **32.15%** probability of full system compromise after privilege escalation.

Verification Note

Recalculated independently using the complement rule: $P(\text{none vulnerable}) = 0.7 \times 0.8 \times 0.75 \times 0.85 = 0.357$, so $P(\text{at least one}) = 1 - 0.357 = 0.643 = 64.3\%$. Full compromise $= 0.643 \times 0.5 = 0.3215 = 32.15\%$. Figures confirmed correct.

Evaluation / Comment

Strengthening file permissions significantly reduces privilege-escalation opportunities, but services must also be patched because initial service vulnerabilities remain a major attack vector.

Additional Insight

The 0.5 privilege-escalation probability is applied as a flat multiplier assuming independence from which service was initially exploited; in practice, different services grant different levels of initial access (e.g. a web service breach may land in a low-privilege web-server account, while an exposed database service could directly expose credentials), so 32.15% should be treated as an average-case estimate rather than a per-service figure. This calculation also shows why the two controls are complementary rather than substitutes: patching drives the 64.3% figure down, while file-permission

hardening drives the 0.5 multiplier down — doing only one leaves the other term unchanged and the overall risk only partially reduced. Recommended priority: patch/harden all four exposed services first (largest single lever, since it is the term with highest weight), then remediate weak file permissions (chmod/ACL review, remove SUID/SGID where unnecessary) as a second layer of defense-in-depth.

Question 4 – NFS Misconfiguration

Brief Explanation

Three internal subnets can attempt unauthorized access to an NFS share. The task is to calculate the probability of unauthorized access, determine the chance of complete compromise through root escalation, and evaluate restricting NFS access as a mitigation strategy.

Key Calculations

- $P(\text{at least one subnet gains access}) = 1 - (0.6 \times 0.7 \times 0.8)$
- $= 1 - 0.336 = 0.664$
- $= 66.4\%$
- $\text{Complete compromise} = 66.4\% \times 0.7 = 46.48\%$

Run Comment (Expected Result)

The probability of unauthorized access is ****66.4%****, while the probability of full system compromise becomes ****46.48%**** after privilege escalation.

Verification Note

Recalculated independently: $P(\text{no subnet gains access}) = 0.6 \times 0.7 \times 0.8 = 0.336$, so $P(\text{at least one}) = 1 - 0.336 = 0.664 = 66.4\%$. Complete compromise $= 0.664 \times 0.7 = 0.4648 = 46.48\%$. Figures confirmed correct.

Evaluation / Comment

Restricting NFS access to only trusted subnets reduces unnecessary exposure and follows the principle of least privilege, making it an effective mitigation.

Additional Insight

Restricting access to a single subnet is only as strong as the weakest remaining path: if the retained subnet is the one with the highest individual access probability (0.4), the residual risk of unauthorized access stays at 40% rather than dropping to near zero, and complete compromise risk would still be $0.4 \times 0.7 = 28\%$. A stronger recommendation is therefore to (a) select the subnet with the **lowest** unauthorized-access probability (0.2) if a single subnet must be retained — reducing residual full-compromise risk to $0.2 \times 0.7 = 14\%$ — and (b) pair NFS export restriction (no_root_squash disabled, root_squash enabled, export lists tied to specific host IPs) with root-escalation hardening, since the 0.7

privilege-escalation term is the larger contributor to the final 46.48% figure and NFS restriction alone does not address it.

Question 5 – SQL Injection Attack Analysis

Brief Explanation

The application firewall blocks the SQL injection after 40 seconds. The task is to calculate the number of records extracted before blocking, determine the percentage of compromised data, estimate sensitive records exposed, and evaluate the effectiveness of the detection mechanism.

Key Calculations

- Extracted records = $500 \times 40 = 20,000$ records
- Compromised percentage = $(20,000 \div 50,000) \times 100 = 40\%$
- Sensitive records exposed = $20,000 \times 30\% = 6,000$ records

Run Comment (Expected Result)

The attacker successfully extracts ****20,000 records****, including approximately ****6,000 sensitive records****, before the firewall blocks the attack.

Verification Note

Recalculated independently: $500 \text{ records/sec} \times 40 \text{ sec} = 20,000 \text{ records}$; $20,000 \div 50,000 = 40\%$; sensitive records = $20,000 \times 0.30 = 6,000$. Figures confirmed correct (this assumes the extraction is uniform, i.e. sensitive records are extracted at the same 30% rate as the overall database).

Evaluation / Comment

Although the firewall eventually stops the attack, exposing thousands of sensitive records indicates that detection alone is insufficient. Input validation, parameterized queries, and stronger preventive controls should be implemented.

Additional Insight

A 40-second detection window at 500 records/second is a large blast radius for a single query-injection session; in practice an attacker using UNION-based or blind SQLi with automated tooling (e.g. sqlmap) can exfiltrate at even higher effective rates, so 20,000 records should be read as a conservative baseline, not a worst case. Because the breach severity scales linearly with detection time, the single highest-leverage improvement is reducing time-to-block, not just raising firewall block rate: halving the detection window to 20 seconds would directly halve exposure to 10,000 records regardless of other controls. Recommended layered defense: parameterized queries/prepared statements and ORM usage to prevent injection at the source (eliminates the vulnerability rather than just detecting it), a Web Application Firewall (WAF) tuned for sub-10-second anomaly

response, rate-limiting on query result volume per session, and encryption or tokenization of the sensitive 30% of records so that even a successful extraction yields low-value data.